

Data discovery and classification

Guardium provides tools to discover and report on databases and to find sensitive data. In this lesson, you learn about configuring the Auto-discovery Process Builder to scan for databases and the data assessment tool to discover sensitive data.

Guardium data risk management process



Data security risk management has five phases:

1. **Asset inventory and classification:** Discover data assets, identify sensitive information, and classify data assets.
2. **Entitlement reporting:** Identify who has access to what and correlate with the type of data and vulnerability risk.
3. **Vulnerability identification:** Identify vulnerabilities in data sources, such as failed CVEs, misconfiguration, default password policies, and excessive privileges.
4. **Risk assessment and remediation:** Rank assets by a risk score rating, identify and prioritize risk remediation steps, implement database and application virtual patches.
5. **Continuous monitoring and metrics:** Use policies and reports to:
 - View real-time access insights to help prevent data loss.
 - Reduce risk in real time with automated dynamic data masking, blocking, alerting, and quarantine.
 - View dashboards of current security risk posture and progress.

Data discovery overview

First step in data risk management

Clients must know what they have before they can protect it

Other tools, such as IBM Discover and Classify, assist with data discovery process, and integrate with Guardium

Scan networks and ports

Discover and classify sensitive data

Create inspection engines for databases on servers that host Guardium S-TAP agents to facilitate monitoring

Data asset discovery and classification is the first step in a risk management plan. Guardium uses two mechanisms for discovery. Each has a different focus:

- A two-step process that first searches for databases by scanning networks and ports, then explores the data that is contained in the discovered databases. The focus of this mechanism is an inventory of data assets, which provides insight about the location and type of sensitive data.
- Guardium agents scan their host to find databases and then create inspection engines for these databases. The focus of this process is to prepare the databases for monitoring by using Guardium policies, and audit by using Guardium reports.

There are several other tools, such as IBM Discover and Classify, that facilitate the data discovery process and integrate with Guardium.

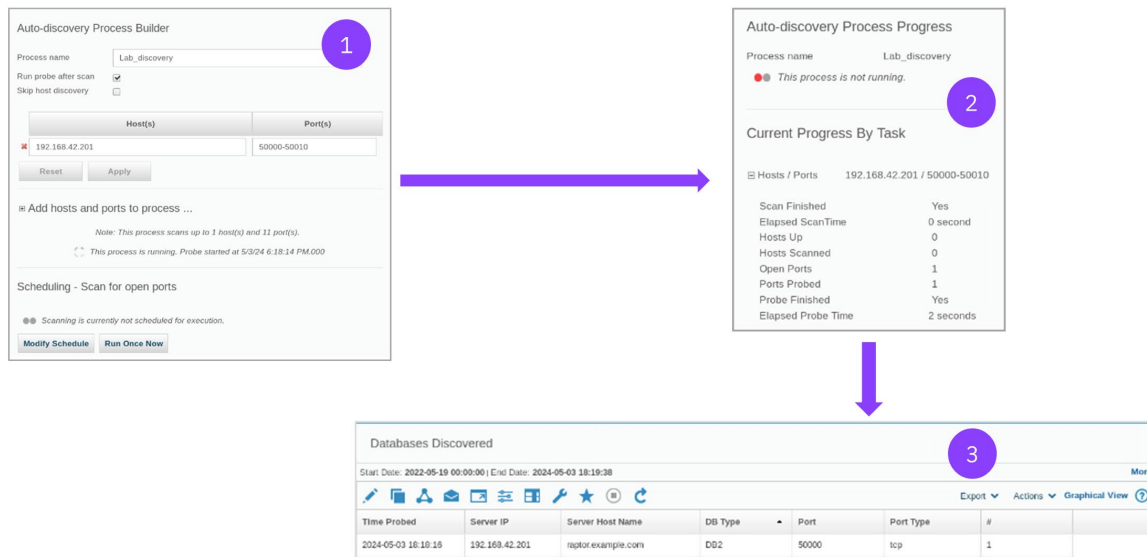
Discovering databases	Scan jobs	Probe jobs
Configure auto-discovery to probe network and report discovered databases Run auto-discovery on demand or schedule periodically	Scans each specified host or hosts in a specified subnet Compiles list of open ports from list of ports specified for that host Must be run before probe job	Uses list of open ports from latest scan job Determines whether database services are running on those ports Results are in the Databases Discovered report

Sometimes a new database is introduced into a production environment outside the normal control mechanisms. For example, the new database might be part of an application package from a software vendor. In older installations, some databases might be unmonitored or “forgotten,” because the data was not seen as a risk when the database was implemented. Another example is that a rogue DBA might create a new instance of the database to avoid being monitored.

Scan jobs search the hosts in a subnet and compile a list of the open ports. It is important to run a scan job before you run the probe job. **Probe jobs** use the list of open ports that are found during the latest scan job and determine whether database services are running on those ports. The results of the probe job are located in the Databases Discovered report.

You can schedule the two jobs individually or define that the auto-discovery process runs the probe job when the scan job completes. The scanning and probing ports processes can take time. To view the progress of an auto-discovery process anytime, click **Progress/Summary**.

Database discovery configuration

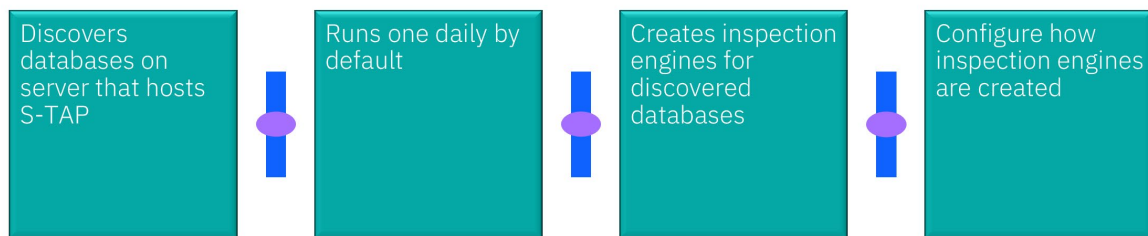


Some companies do not have a full inventory of their database servers and do not understand where all their sensitive data exists. Database Discovery probes a network to identify servers that run database services. Data Classification scans databases to find and classify objects or fields that contain sensitive data.

With the Auto-discovery Process Builder, you specify which hosts and ports to scan. Scanning is a two-step process. In the first step, Guardium scans the specified port range on the hosts. The second step probes the ports that were discovered in the first step to determine whether database services run on those ports.

You can run the scan once or schedule it. You can monitor the process. After the process completes, the Databases Discovered report lists the results.

S-TAP database discovery



S-TAP agents also discover new database instances. This process is different from the database auto-discovery process described on the previous two slides.

The auto-discovery process probes the network for hosts and ports that might indicate databases, then lists discovered databases in a report, but does not manage them or create inspection engines for them. This process is useful for finding unknown and possibly unauthorized databases in the network environment. But to bring these database instances under Guardium management, you must take more steps, such as installing an S-TAP agent on the database server.

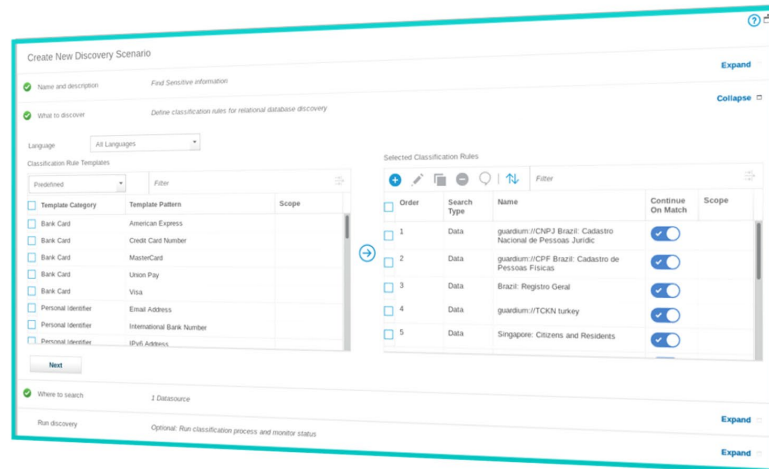
The S-TAP agent discovers only instances that run on the database server that hosts the S-TAP agent. By default, the S-TAP database discovery process runs daily. Guardium creates inspection engines for the instances that the S-TAP agent discovers. You can configure the inspection engine creation rules to control how inspection engines are created and modified for discovered databases.

Discovering sensitive data

Examine discovered databases

Look for patterns, which match sensitive data

Use existing rules or create a custom rule



While the previous two methods of discovery are useful for finding database instances, they do not identify the type of data in the databases.

Data security requires finding and classifying sensitive data to be monitored, protected, and audited. Organizations might need to comply with data security standards such as GDPR or CCPA, or have specialized criteria for what constitutes sensitive data. Even the stakeholders who own the data might not fully understand what constitutes sensitive information and where it might exist.

After Guardium discovers databases, either through a network probe or the S-TAP, you can use the Discovery Scenario tool to examine the databases for sensitive data. Discovery scenarios can examine relational databases or unstructured data. You can use preconfigured rules from an existing template, or define a custom rule to implement an organizational policy.

Discovery scenarios include a datasource, which defines where to look for data, and a set of rules, which define what type of data to discover. These rules can be complex. Therefore, Guardium provides templates with predefined rules, which you can copy and modify. In a new discovery scenario, you must choose an existing discovery policy as a template to inherit its rules. You can remove or add more predefined rules. You can also create a new rule, although that task is complex, requires testing, and is beyond the scope of this foundations course.

Discovery scenario templates

Preconfigured rules focus on these scenarios

- CCPA
- GDPR
- PCI
- PII

Discovery Scenarios	
 	Filter
CCPA [template] (CCPA [template])	
CCPA for Db2 for z/OS [template] (CCPA for Db2 for z/OS [template])	
GDPR (GDPR) (Relational)	
GDPR [template] (GDPR [template])	
GDPR Document (GDPR) (Document)	
GDPR for Db2 for z/OS [template] (GDPR for Db2 for z/OS [template])	
PCI [template] (PCI [template])	
PII [template] (PII [template])	

Guardium provides discovery scenario templates with preconfigured rules for various regulations:

- California Consumer Privacy Act (CCPA)
- General Data Protection Regulation (GDPR)
- Payment Card Industry Data Security Standard (PCI)
- Personal Identifiable information (PII)

Running the discovery scenario

Run once or schedule periodically

Review results

Define ad hoc grouping and alerting actions

Set up audit process to distribute results

The screenshot shows the Guardium Data Protection interface. At the top, there are two dropdown menus: 'Add to Group' and 'Advanced Actions'. The 'Add to Group' menu is open, showing options: 'Add to Group of Object', 'Add to Group of Object/Field', 'Add to Group of Schemas to Exclude', 'Add to Group of Tables to Exclude', and 'Add to Group of Tables/Columns to Exclude'. The 'Advanced Actions' menu is also open, showing options: 'Alert on access to sensitive data', 'Create access rule', 'Create privacy set', 'Ignore', 'Log policy violation', 'Log result', and 'Send alert'. Below these menus is a table with the following columns: Catalog, Schema, Table Name, Column Name, and Rule Description. The table contains several rows of data, including 'DB2INST1', 'CC', 'FIRSTNAME', 'LASTNAME', and 'TXN_DATE_TIME'. The bottom of the table shows 'Total: 89 Selected: 89' and a page number '1'.

Catalog	Schema	Table Name	Column Name	Rule Description
☒	DB2INST1	CC	FIRSTNAME	first name [first name] [en]
☒	DB2INST1	CC	FIRSTNAME	fname [fname] [en]
☒	DB2INST1	CC	LASTNAME	last name [last name] [en]
☒	DB2INST1	CC	LASTNAME	lname [lname] [en]
☒	DB2INST1	CC1	TXN_DATE_TIME	date [date] [en]
☒	DB2INST1	CC1	FIRSTNAME	first name [first name] [en]

Total: 89 Selected: 89

< 1 >

You can run a discovery scenario on demand or schedule it to run periodically. After it runs, you review the results. You can perform actions on the discovered data, such as creating alerts on the discovered data or adding sensitive data objects to a group of sensitive objects.

You can also use Guardium audit process automation to distribute the results to data security stakeholders. Audit process automation is discussed in another unit.

